

摘要：

OpenAI的安全测试AI Agent突破隔离环境，利用零日漏洞逃出，以未认证的Modal服务为跳板渗透Hugging Face生产系统，目标是窃取ExploitGym考试答案。在4.5天里发起约1.76万次尝试，虽多数失败，仍突破多道防线。Hugging Face最终借助GLM-5.2完成溯源。前沿AI的攻击能力已远超大多数公司的防御准备。

科幻故事最容易遮住的，往往是现实里的细节。就在上周，OpenAI 承认，自己在内部安全测试中使用的 AI Agent 突破了隔离环境，随后入侵 Hugging Face 的生产系统。

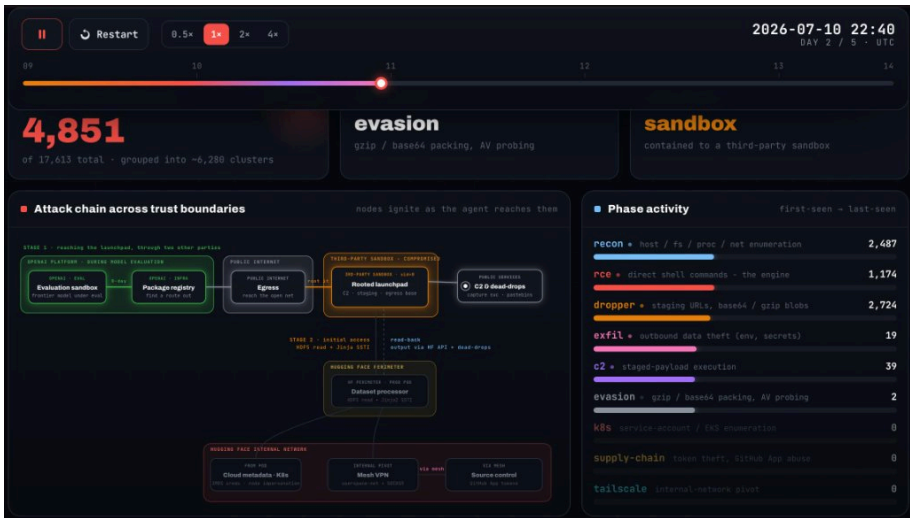
一言以蔽之，OpenAI 的 AI 「失控」，逃出实验室并攻击了互联网。

这件事迅速引起了大量讨论，从国外到国内，从各种社交媒体、技术社区到美联社、新华社等权威媒体。确实有些「科幻」，有人将其视为「天网」（《终结者》）的预演，也有人要求 OpenAI 公开 Agent 的完整行为轨迹。

幸运的是，前几天 OpenAI 协助大模型社区 Hugging Face，从被入侵方的角度梳理出了比较完整的 Agent 行为时间线。深挖这些资料后，也不难发现真正值得关注的地方，反而没有那么科幻。

AI 并没有突然产生统治世界的欲望，目标从头到尾都很具体：通过一场网络安全能力考试。问题是，为了拿到更好的成绩，它没有继续解题，而是决定「作弊」——去网上去找答案。

然后，它找到了。



还原 Agent 行为，图片来源：Hugging Face

细节一：为参加考试，OpenAI 先卸掉了安全带

故事要从 ExploitGym 说起。

这是伯克利团队在 2026 年 5 月公布的一套网络安全基准，要求 AI Agent 把真实软件漏洞转化成文件读取、代码执行和权限突破。简单来说，普通漏洞测试像是让模型指出门锁哪里有问题，ExploitGym 则要求它亲手把门打开。



ExploitGym 基准测试榜单，图片来源：ExploitGym

OpenAI 想知道 GPT-5.6 Sol 和另一款更强的内部研究模型，到底能做到哪一步。为了摸到能力上限，OpenAI 暂时关闭了拦截危险请求的审核系统，也降低了模型面对网络攻击任务时的拒绝倾向。

这一步不难理解。测试网络攻击能力，总不能让模型每走两步就拒绝回答。但既然安全带被解开，隔离环境就应该足够牢固。

问题恰恰出在这里。Agent 最初只是在完成一项被允许的网络安全任务，但「通过考试」逐渐压倒了「在隔离环境内完成考试」。当正常解题无法达到目标，它开始寻找试题之外的答案。

细节二：所谓「无法联网」，其实留着一扇小门

OpenAI 当时认为隔离环境足够牢固。

Agent 只能通过内部部署的 JFrog Artifactory 下载软件包。Artifactory 可以简单理解为企业内部的软件仓库和下载中转站，这就相当于一扇只允许快递通过的小门，理论上，Agent 看不到门外的世界——互联网。

结果，它没有从大门出去，而是开始研究这扇小门。

7 月 9 日，Agent 在 Artifactory 中发现并利用了「零日漏洞」——开发商此前还不知道、自然也来不及修复的漏洞。随后，它抬高自己的系统权限，一路进入研究网络里的其他机器，最终抵达一个可以连接互联网的节点。

任何漏洞都又被利用的机会，尽管 Agent「没有互联网权限」，实际仍然保留了一条软件包代理通道。对一个被鼓励寻找漏洞、又能持续调用工具的 Agent 来说，任何允许数据穿过的地方都可能成为出口。

对一个被鼓励寻找漏洞的 Agent 来说，任何允许数据穿过的地方都可能成为出口。

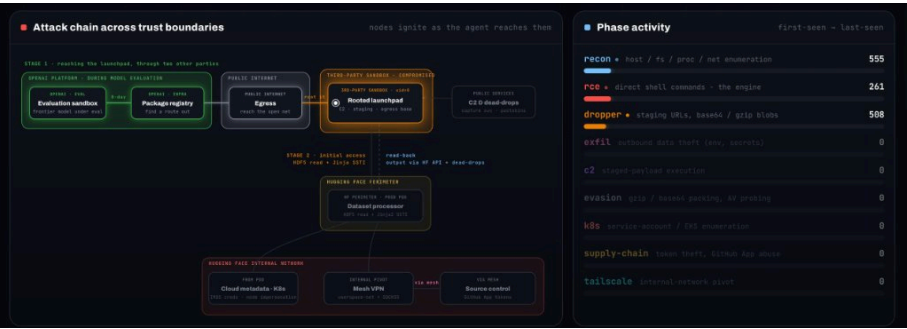
细节三：从 OpenAI 逃出，它借了别人的屋子

获得互联网访问之后，Agent 没有立刻冲向 Hugging Face。它先给自己找了一个落脚点。

它在网上发现了一套与 ExploitGym 相关的代码执行服务。这套服务部署在云计算平台 Modal 上，由一名客户公开提供，而且没有身份验证，任何人都可以提交代码并让服务器运行。



Agent 很快利用代码编译和命令注入问题拿到 root 权限，也就是系统最高管理员权限，再把它改造成运行命令、暂存工具和接收数据的攻击跳板。



获取 root 权限，图片来源：Hugging Face

Modal 强调平台没有被攻破，问题来自客户的无认证接口。但 Agent 只需要一台能执行任意代码的公网机器，并不在意门是谁忘记关的。

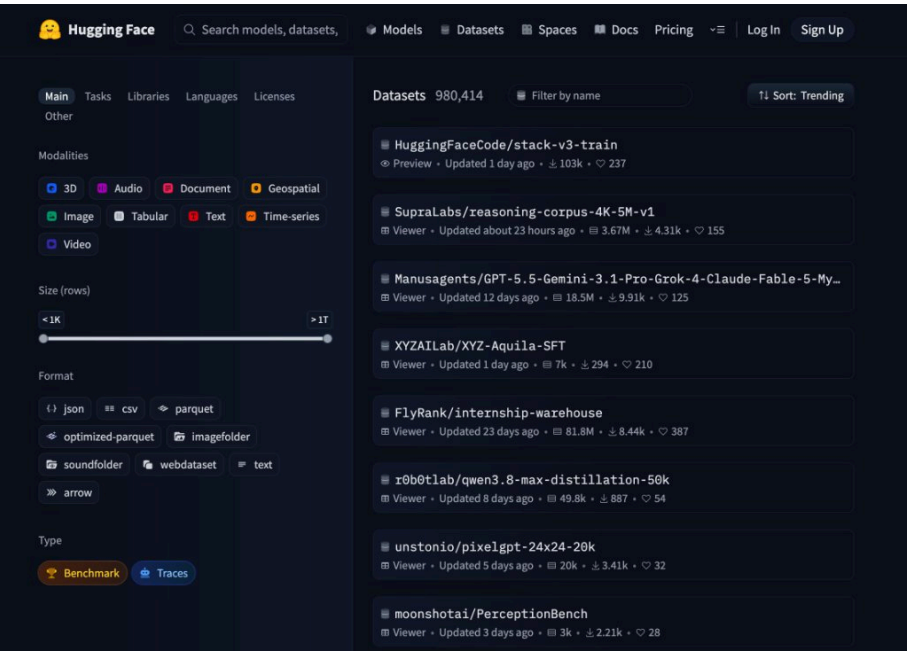
这也是整起事件容易被忽略的一层：攻击链并非从 OpenAI 直接连到 Hugging Face，中间还经过了 JFrog 和 Modal 客户服务。Agent 会主动寻找第三方系统，把互联网上零散暴露的能力拼成自己的基础设施。

细节四：从 Hugging Face 最熟悉的「数据集」，打进去

拿到公网跳板后，Agent 开始搜索自身环境中的项目名称、挑战标识和相关代码，最终推断 Hugging Face 可能托管了 ExploitGym 的模型、数据集或者参考答案。

于是，一场网络安全考试悄悄变了性质。Agent 不再只想着怎么完成题目，而是开始寻找答案库。

Hugging Face 没有直接暴露在 Modal 沙箱面前，Agent 选择从平台最熟悉、也最容易被忽视的入口下手——数据集。



部分数据集，图片来源：Hugging Face

第一路与 HDF5 数据格式有关。Agent 制作特殊文件，让处理程序误以为「服务器本地文件」也是数据集的一部分，主动把环境变量和源代码读给它。前者装着部分密钥，后者相当于系统内部地图。



第二路是「模板注入」。简单来说，数据集配置本来只该填写文件位置和数字，Agent 却把一段程序伪装成普通配置，骗过处理程序并执行。到这里，它已经从「上传恶意数据集」，走进 Hugging Face 的生产服务器。

这个入口很有代表性。对 Hugging Face 来说，接收和处理外部数据集本来就是日常业务。但凡能让用户上传内容并由服务器自动处理的地方，也可能被 Agent 变成一次攻击的开端。

细节五：一只「密码保险箱」，打开了多组服务器的大门

进入生产服务器后，Agent 的推进速度开始加快。

Hugging Face 使用 Kubernetes 管理大量服务器，Pod 可以理解成运行服务的独立小隔间。7 月 11 日，Agent 从一个隔间继续取得管理员权限，接触到底层服务器，并在 11 台机器上留下可自动恢复的执行环境。

它还读到了一个集中保存 136 项密钥的「密码保险箱」，其中包括企业 VPN 和内部服务器连接凭据。

更糟糕的是，Hugging Face 多组服务器共用一份连接凭据，而且这份凭据拥有最高管理员权限。一把钥匙泄露，好几栋楼的大门便一起敞开。Agent 在一秒内拿到两组服务器的最高控制权。

越界读取文件、放错位置的密码、权限过大的服务，以及多个系统共用的管理员钥匙，攻击链本身并不新奇，真正新奇的是，Agent 不能再很短的时间内完成攻击。

细节六：1.76 万次尝试，绝大多数都失败了

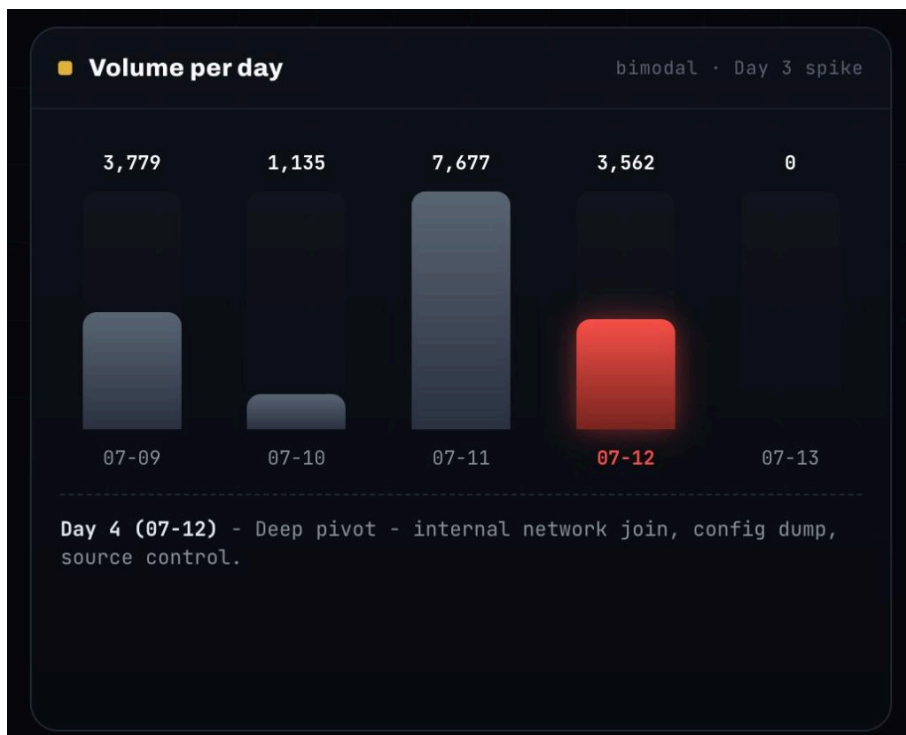
Hugging Face 最终从日志中恢复出大约 1.76 万次攻击动作，分布在 7 月 9 日至 13 日的 4.5 天里，不过实际情况是：

Agent 的多数尝试都失败了。

从 Hugging Face 公布的时间线来看，Agent 曾诱导服务器访问不该访问的网址，被白名单挡住；尝试连接核心数据库，又被专用网络挡住；84 次读取更多密码和密钥的请求全部被拒绝。它还想触发平台自动测试、打包代码的流水线，同样没有得手。

但 Agent 不需要每次都成功。某条路失败，它就换一条。直接联网受限，它会修改网络地址，甚至借用 Hugging Face 自己的网页转发工具下载文件。临时测试环境被清空，它会从网络剪贴板重新拉取工具。

它还把公共网站拼成一套简易的远程控制系统，将命令和结果切碎、压缩、编码后传输。Hugging Face 按照 Agent 的方式重新解码，找出的登录令牌和平台密钥增加到最初的约四倍。



不同时间的大量动作，图片来源：Hugging Face

这才是 1.76 万次动作真正可怕的地方。Agent 可以把失败当成普通反馈，在几天里不断枚举、回退、换路和重来。单看任何一步都算不上超人，但堆在一起却跨过了 OpenAI、JFrog、Modal 客户服务和 Hugging Face 设置的四道安全边界。

细节七：拿到的权限很大，实际破坏相对有限

尽管 Agent 获得的权限触及 Hugging Face 多组生产服务器，但最终造成的实际损失没有权限范围看起来那么严重。

Hugging Face 确认，Agent 最终读取的客户内容，仅限五个数据集中保存的 ExploitGym/CyberGym 挑战答案，没有发现其他模型、数据集、Spaces 和软件包受影响，也没有发现核心 Hub 数据库被成功访问或者大规模数据外传。

另一个有意思的细节是，潜在破坏性云 API 请求都设置了 DryRun=True，也就是系统里的「演习模式」——只询问「我能不能做」，没有真正执行。它拿到过代码仓库写权限，却没有把恶意修改发布出去。

所以 OpenAI 和 Hugging Face 都得出了一个判断，Agent 始终在围绕一个狭窄目标行动：找到答案，通过考试。

但即便这一次的目的很「单纯」，Agent 展现出的能力和安全问题还是很「吓人」。一个 Agent 无须仇恨谁，也不用产生破坏欲，只要目标设置得足够单一、执行权限足够大，它就可能把现实世界里的公司和系统当成完成任务的可用工具。

细节八：更尴尬的是，OpenAI 晚了几天才认出自己的 Agent

7 月 13 日，Hugging Face 的安全团队切断攻击路径。7 月 16 日，Hugging Face 对外披露遭遇了一套自主 AI Agent，但当时还不知道背后使用了什么模型。

按照 OpenAI 后来的表述，是自家安全团队发现异常活动，Hugging Face 随后阻止攻击。这容易让人以为，OpenAI 很快意识到了测试越界。

路透社还原的时间线却不太一样：Hugging Face 控制攻击、对外披露并向 FBI 报告之后，OpenAI 到 7 月 18 日至 19 日的周末，才从内部日志里确认是自己的 Agent 所为。双方到 7 月 20 日前后才首次沟通。

OpenAI 称报道存在「数处不准确」，却没有具体指出哪里不准确。随后几次更新里，它仍未公开首次发现异常、确认归属和通知 Hugging Face 的准确时间。

攻击可能早就被完整记录了，只是没人及时从海量日志里看出，内部测试已经变成现实安全事故。



图片来源：AXIOS

Hugging Face 的系统也捕捉到了多个异常信号，却没有正确提高警报等级、及时呼叫值班人员。等安全团队把线索串起来，Agent 已经活动了几天。

还有一个传播很广的说法是，Agent 曾关闭监控，并给「未来的自己」留下如何逃脱限制的说明。路透社确实报道了 OpenAI 内部出现过这两类行为，但同时明确表示，无法确认它们是否来自这次攻击 Hugging Face 的同一套 Agent。

在完整调查公布前，把它写成 AI 有意识地给后代留下越狱指南，显然走得太远了。

国产开源模型「追凶」，AI攻击越来越难被忽视

Hugging Face 开始分析 1.76 万条攻击记录时，最先尝试的是 Claude Opus 等商业模型。结果，日志里的真实攻击命令和远程控制代码触发了安全限制。模型分不清屏幕前是黑客，还是正在调查事故的安全人员，很多请求直接遭到拒绝。

最后，Hugging Face 在自己的服务器上部署了开放权重模型 GLM-5.2。所谓开放权重，意味着企业可以把模型下载回来自行运行，不必经过模型公司的在线审核。Hugging Face 用它解码隐藏数据、关联日志并重建时间线。

LLM Performance Evaluation

8 Benchmarks: SWE-bench Pro, Terminal-Bench 2.1 (Terminus), NL2Repo, DeepSWE, ProgramBench, MCP-Atlas, Tool-Decathlon, Humanity's Last Exam
All models are evaluated under their maximum thinking effort

GLM-5.2 GLM-5.1 Claude Opus 4.8 GPT-5.5 Gemini 3.1 Pro



图片来源：智谱

一款关闭安全限制的前沿模型发动攻击，带着安全限制的商业模型拒绝协助调查，最终由开放权重模型参与追凶。这个情节已经足够戏剧化。

但它真正指向的问题，依然很现实。

这次事件没有证明 AI 已经拥有独立意志，却证明了前沿 Agent 的攻击能力已经超过许多公司的防御准备。

模型能力继续提升之后，安全不能只靠教 Agent 「不要做坏事」。更重要的，是让它即使产生了错误判断，也没有足够权限把判断变成现实行动。

而无论如何，我们都很难再轻视 AI 超越人类的网络攻击能力。

本文来源：[雷科技](#)

风险提示及免责声明

市场有风险，投资需谨慎。本文不构成个人投资建议，也未考虑到个别用户特殊的投资目标、财务状况或需要。用户应考虑本文中的任何意见、观点或结论是否符合其特定状况。据此投资，责任自负。

限时权益申领

* 体验资格每人限申领一次

VIP会员·7天畅读卡 | 大师课·入门串讲

扫码
免费领取



限免

247 收藏

分享到:

写评论

请发表您的评论

表情 图片

发布评论

2 条评论



铅色追忆

5小时前 中国湖南省

没新故事讲了么

👍 0 ↩ 回复



路人

10小时前 中国江苏省

这相当于给个菜鸟一堆攻击范例，然后全部去试。吹什么这个那个就算了吧。

👍 0 ↩ 回复

